

Table of contents

1. BEC Response Playbook	2
1.1 Document Control	2
1.2 Purpose	2
1.3 Scope	3
1.4 Response Flowchart	3
2. 1. Preparation	4
3. 2. Identification	5
3.1 Activation	5
3.2 Immediate Triage Questions	5
3.3 Evidence to Preserve	6
3.4 Investigation	6
3.5 Communications and Notifications	7
4. 3. Containment	8
5. 4. Eradication and Remediation	8
6. 5. Recovery	9
6.1 Closure Criteria	9
7. 6. Lessons Learned	10

1. BEC Response Playbook

Document version: 1.0

Generated: 27 July 2026

Generated with: [Skriiv](#)

Validation: Pass

Licence: [CC BY 4.0](#)

1.1 Document Control

Field	Detail
Document ID	[Document ID to be assigned by playbook owner]
Author	[Author]
Playbook owner	[Playbook Owner]
Approved by	Not supplied
Version	DRAFT
Approval date	Pending approval
Review date	Pending approval
Classification	[Classification]

Publication prerequisite: This draft cannot be approved for operational use until the organisation supplies and confirms: applicable jurisdiction(s) (see Scope); the deployed email/identity platform, edition and administrator capabilities (see Preparation); incident severity thresholds and escalation/decision authorities (see Response Flowchart, Activation); named response roles and escalation contacts, including finance, legal, privacy and communications functions (see Communications and Notifications); enabled logging sources and retention (see Preparation, Evidence to Preserve); approved bank fraud and cyber-insurance contacts and procedures (see Containment, Recovery); and recovery-validation and closure sign-off roles (see Recovery, Closure Criteria). These items are marked as placeholders and assumptions throughout this document; none is established by the evidence used to draft it.

1.2 Purpose

This playbook provides a structured response process for suspected or confirmed business email compromise (BEC) incidents. Government-source material supplied for this draft describes BEC as fraud that abuses trust in business email or payment processes, typically through impersonation of a trusted sender or through compromise of a genuine business email account, commonly to redirect payments or to obtain information.

Some source material distinguishes business-focused email compromise from compromise of consumer personal accounts in the specific context of fraudulent-transfer reporting to financial institutions. That distinction is included here only for context and should not be treated as a universally applicable classification outside that reporting context.

Author caution: The definitional sources underpinning this Purpose section were reviewed via search-index summaries or are dated (2015 and 2019 respectively). Reverify current government guidance before relying on specific terminology in a final version of this document.

1.3 Scope

This playbook covers two related but distinct BEC scenarios, which should be treated as separate response branches because the applicable evidence and containment actions differ:

- **External impersonation** — a message purporting to come from a trusted sender (executive, vendor, or colleague) without evidence that any genuine account was accessed.
- **Compromise of a genuine mailbox or account** — unauthorised access to a real business email account, which may then be used to send fraudulent messages, intercept correspondence, or enable further phishing.

Supported incident scenarios in scope include:

- Vendor or invoice payment redirection following a changed or disputed supplier banking detail.
- Executive impersonation payment request, where a message purporting to come from an executive or other authority figure induces an urgent, confidential, or approval-bypassing payment.
- Payroll banking-detail diversion affecting salary payments.
- Use of a compromised email account to send further phishing or fraudulent messages to internal or external recipients.
- Real estate or settlement payment fraud, where relevant to the organisation's sector or transactions.

Assumption requiring confirmation: No specific jurisdiction is assumed to govern the organisation, affected individuals, or relevant transactions. Legal notification, reporting, and financial-recovery content in this playbook are jurisdiction-dependent and must be confirmed by the organisation's legal or compliance function before operational reliance. Jurisdiction confirmation is a blocking prerequisite for approving this playbook for operational use.

Assumption requiring confirmation: Neither Microsoft 365, Google Workspace, nor any other specific email or identity platform is assumed. Evidence, logging, containment, and eradication capabilities differ by platform and edition; platform-specific steps in this playbook must be confirmed or rewritten by IT or email administration before use.

Assumption requiring confirmation: No sector-specific regulatory regime is assumed. The evidence available for this draft does not establish that real estate or financial services (or any other sector) carries specific regulatory obligations for BEC incidents; these are given elsewhere in this playbook only as illustrative incident scenarios, not as examples of regulated sectors. If the organisation operates in a regulated sector, additional notification or escalation obligations may apply and should be confirmed by legal, compliance, or risk functions.

This playbook must not be approved for operational use until the organisation confirms: applicable jurisdiction(s), the deployed email/identity platform and edition, and any sector-specific obligations. [Organisation to confirm these items before this playbook is approved for operational use.]

1.4 Response Flowchart

flowchart TD

```

A[Suspected BEC-related activity identified] --> B{Impersonation only, or suspected mailbox/account compromise?}
B -->|Impersonation of a legitimate sender; no evidence of account access| C[Activate impersonation-only response branch]
B -->|Suspected unauthorised access to a genuine mailbox| D[Activate mailbox-compromise response branch]
C --> E{Has a payment been made, or is one pending/interruptible?}
D --> E
E -->|Payment made or pending| F[Urgent: notify relevant financial institution(s) to request intervention - see Containment]
E -->|No payment involved, or already stopped| GATE
  
```

```

F --> GATE{Mailbox-compromise branch: has technical containment been completed, formally deferred, or confirmed not re
H --> GATE
GATE -->|No, mailbox-compromise branch not yet resolved| H
GATE -->|Yes| G[Proceed to evidence preservation and investigation]
G --> I[Investigation: vector, access period, activity, affected recipients]
I --> J[Communications and notification assessment - legal/privacy review]
J --> K[Eradication and remediation]
K --> L[Recovery]
L --> M{Closure criteria met?}
M -->|No| I
M -->|Yes| N[Close incident; complete Lessons Learned]

```

[Organisation to confirm decision-making authority and escalation thresholds at each branch point once its severity model and incident-response roles are defined.]

2. 1. Preparation

- Confirm and document the organisation's approved process for verifying payment-detail changes or large transfers, including independent verification of banking-detail changes through an established contact method rather than details supplied in the request itself. [Organisation to confirm its approved verification channel(s) and thresholds.]
- Confirm multi-factor authentication (MFA) coverage for email and related identity accounts, and record any authentication paths (including legacy authentication protocols) that do not enforce MFA. [Organisation to supply current MFA coverage and any exceptions.]
- Confirm which audit or activity logging sources are enabled for the deployed email/identity platform, the retention period, and the access permissions required to query them. Available historical evidence during an incident depends on this configuration; do not assume that logging is available or retroactive without confirming current platform settings.
- Where the organisation uses Microsoft 365, confirm access to unified audit log search and the roles/licensing required for supported operations.
- Where the organisation uses Google Workspace, confirm the administrator's access to the security investigation tool and the Workspace edition, as available data sources and remediation actions depend on edition.

[Organisation to confirm deployed email/identity platform, edition, and administrator capability inventory before finalising this section.]

Author caution: ACSC guidance drawn on in this Preparation section was reviewed only via search-index summaries rather than direct inspection. The Microsoft and Google vendor documentation drawn on in this section was directly inspected, though specific feature, licensing and retention details within that documentation were not fully verified. Reverify current ACSC guidance and confirm tenant-specific configuration against current vendor documentation before publication.

3. 2. Identification

3.1 Activation

Activate this playbook when one or more of the following occur:

Criterion	Threshold/example
Suspected or reported payment redirected to a fraudulent account	An invoice, supplier, or payroll payment was made or is pending to a banking detail that was recently changed or disputed.
Message suspected of impersonating a trusted sender	A message purports to come from an executive, vendor, or colleague and requests payment, urgent action, confidentiality, or an exception to normal approval processes.
Suspected unauthorised access to a genuine mailbox	Evidence suggests a real account, rather than only an external sender identity, may have been accessed without authorisation.
Suspicious mailbox rule or forwarding-rule change	An unexplained forwarding or deletion rule is identified on a business mailbox. Other rule types (for example, rules that hide or archive messages) are not established as a supported indicator by the evidence used to draft this playbook and should be treated as an unresolved platform-verification question if identified.
Real estate or settlement transaction affected	A property or settlement-related payment is suspected of BEC-style redirection, where relevant to the organisation's transactions.

[Organisation to map these criteria to its own incident severity matrix and escalation thresholds; none is supplied by the evidence used to draft this playbook.]

3.2 Immediate Triage Questions

- Has a suspected fraudulent payment been made, is one still pending, or can it still be interrupted? (This determines whether urgent financial-institution engagement is required — see Containment.)
- Which internal finance or payment process is implicated (invoice/vendor payment, payroll, or another transaction)? [Organisation to identify the responsible internal finance contact.]
- Does the incident involve only external impersonation, or is there evidence of unauthorised access to a genuine mailbox?
- If a genuine mailbox may be involved, was MFA enabled on the affected account, and was any non-MFA authentication path used? [Requires organisation-specific platform/MFA data.]
- Are there any unexplained mailbox rules (forwarding or deletion rules) on the affected account? (Other rule types identified during investigation, such as rules that hide or archive messages, should be treated as an unresolved platform-verification question rather than an established indicator.)
- Who is the affected account's owner, and what is their role in payment approval or authority? (Relevant where the incident involves executive impersonation or a request to bypass normal approval.)

[Organisation to supply approved bank contacts, internal escalation contacts, and severity thresholds to complete this section.]

3.3 Evidence to Preserve

Preserve evidence appropriate to the deployed platform. Candidate categories, based on the evidence available for this draft, include:

- Relevant message data (the suspected fraudulent or impersonating message(s), headers, and related correspondence).
- Mailbox configuration changes (for example, forwarding or inbox rules identified during triage).
- Third-party or connected-application information, where available on the platform.
- Account and authentication activity (sign-in and audit records), where enabled and retained.

Where the organisation uses Microsoft 365, the unified audit log is a candidate source, subject to confirming the applicable roles, enabled record types, licensing, and retention. Where the organisation uses Google Workspace, the security investigation tool is a candidate source for device, Gmail, Drive, and account data, subject to confirming Workspace edition and administrator permissions.

Author caution: Do not assume equivalent evidence availability across platforms or editions. Confirm the actual platform, enabled logging, retention, and access permissions before defining collection procedures. [Organisation/IT to supply current logging and retention configuration.]

3.4 Investigation

The investigation should determine:

- The likely initial access vector for any genuine account compromise (for example, credential phishing, use of previously compromised credentials, or password attacks), compared against available authentication and account evidence.
- The estimated period of unauthorised access and the mailbox activity observed during that period, based on available platform audit evidence. Where telemetry is unavailable or incomplete, this should be described explicitly rather than treated as evidence that no access occurred.
- Whether the compromised identity, if applicable, was used to send further phishing or fraudulent messages, based on available sent-message and message-trace data. Note that available records may not produce a definitive recipient list.
- Which log sources were actually available and queried, and which desired evidence categories could not be obtained.
- Whether the information involved may meet the threshold for a legal notification assessment (see Communications and Notifications) — this determination requires confirmation of applicable jurisdiction and qualified legal input, which are not established by the evidence used to draft this playbook.

[Organisation to confirm applicable jurisdiction and platform before finalising investigation procedures — see Scope.]

3.5 Communications and Notifications

Consider notification to:

- **Internal escalation** — [Incident Response Lead], finance/treasury, and executive stakeholders as applicable, per the organisation's escalation chain. [Organisation to supply escalation contacts and communication owner.]
- **Relevant financial institution(s)** — where a suspected fraudulent transfer has occurred, promptly contact the relevant financial institution(s) to request available intervention. This action may need to occur before the technical investigation is complete. [Organisation to pre-populate approved bank fraud contacts and recall/hold procedures.]
- **Affected or at-risk contacts** — where a compromised or impersonated identity may have exposed other parties to related fraudulent messages, consider warning identified contacts using organisation-approved communications, based on available recipient and message evidence.
- **Legal or privacy function** — obtain legal or privacy assessment before determining whether external notification obligations apply. In Australia, the Notifiable Data Breaches (NDB) scheme requires notification to affected individuals and the Office of the Australian Information Commissioner (OAIC) where a covered entity experiences an eligible data breach involving unauthorised access, disclosure, or loss of personal information likely to result in serious harm that cannot be prevented through remedial action. Applicability to this organisation, and the specific timing of any required assessment, must be confirmed with qualified legal advice — the evidence available for this draft does not establish a fixed numeric assessment deadline. [Organisation to confirm applicable jurisdiction(s) and obtain qualified legal review.]
- **National cybercrime or fraud reporting channel** — where applicable to the organisation's jurisdiction, consider reporting to the relevant national channel (for example, the FBI's IC3 in the United States, or ACSC/ReportCyber in Australia). This is presented as an available reporting option; the evidence for this draft does not establish that such reporting is a binding legal obligation for a BEC incident, nor that it is universally applicable.
- **Regulator guidance for financial institutions (context only)** — US FinCEN guidance on BEC/EAC reporting is addressed primarily to financial institutions and does not, on the evidence available, establish an equivalent direct reporting obligation for the affected organisation itself. Include only if the organisation or transaction falls within the relevant US context.
- **Cyber-insurance provider**, where applicable. [Organisation to confirm policy notification conditions and timing.]

Unresolved research question: Whether a failure to notify under Australia's NDB scheme constitutes an interference with privacy attracting civil penalties for corporate entities was not established by the source material reviewed for this draft and requires verification against current legislation and qualified legal review before any such statement is included in operational guidance.

Author caution: Do not treat any of the above as a universally applicable legal obligation. Jurisdiction, sector, and contractual applicability must be confirmed by qualified legal or privacy review before publication. Confirmation of applicable jurisdiction is a blocking prerequisite for approving this section for operational use (see Scope).

4. 3. Containment

Containment actions may include:

- **Financial containment (urgent, may run in parallel with technical containment):** Promptly contact the relevant financial institution(s) to request intervention on a suspected fraudulent transfer, using organisation-approved bank contacts and recall/hold procedures. [Organisation to supply these contacts and procedures.]
- **Technical containment (for confirmed or suspected mailbox compromise only — not applicable to impersonation-only incidents):** Use the deployed platform's verified capabilities to address unauthorised account access and any malicious mailbox configuration or application access identified during investigation (for example, credential reset, session review, and review of mailbox rules and connected applications). The exact actions and their sequencing depend on the platform and must be confirmed against current vendor procedures and organisational authority before execution.
- **Contact warning:** Where identified, warn contacts placed at risk by a compromised or impersonated identity, using organisation-approved communications (see Communications and Notifications).

Author caution: Whether a password reset alone is sufficient to contain a mailbox compromise is not established by the evidence available for this draft — the cited vendor material confirms investigation and remediation capabilities but does not establish the exact set of access mechanisms (for example, active sessions, delegate access, forwarding rules, or application grants) that may remain active after a password reset. Treat the adequacy of any single containment action as an unresolved platform-verification question, and confirm the current, platform-specific set of required containment actions against current vendor documentation before execution. [Organisation/IT to confirm platform-specific containment procedures.]

5. 4. Eradication and Remediation

Remediation actions may include:

- Removing malicious mailbox configuration identified during investigation (for example, unauthorised forwarding or inbox rules) using verified procedures for the deployed platform, once relevant evidence has been preserved and the change has been recorded per organisational procedures. The complete set of configuration objects requiring review (rules, delegates, transport/connector rules, and similar) is platform-specific and must be confirmed rather than assumed.
- Reviewing whether legacy authentication protocols were a relevant control gap, and confirming current platform support, dependencies, and change-approval procedures before disabling any protocol. Do not prescribe protocol changes without platform verification and a service-impact assessment.

Unresolved research question: Whether OAuth or other third-party application grants can persist independently of a password reset, and what token-rotation or revocation actions this may require, was not established by the source material reviewed for this draft. This must be verified against current vendor documentation for the deployed platform before being treated as a remediation requirement. [IT/platform administrator to verify current application-consent and token-handling procedures.]

[Organisation to confirm the deployed platform and its current eradication procedures before this section is relied upon operationally.]

6. 5. Recovery

Recovery actions may include:

- Restoring normal mail flow and account access following containment and eradication is a general incident-response objective. A specific, verified technical recovery checklist for BEC mailbox incidents was not established by the evidence available for this draft (see the unresolved research question below). Restoration of mail flow and account access should not be treated as a defined, ready-to-execute recovery action until the organisation supplies and verifies platform-specific recovery procedures. [Organisation/IT to confirm the applicable recovery steps for its platform.]
- Where a suspected fraudulent transfer falls within US jurisdiction, the FBI IC3's Recovery Asset Team and Financial Fraud Kill Chain mechanism is described in supplied government material as intended to support attempts to freeze fraudulently transferred funds. Current eligibility, transaction scope, and reporting steps must be confirmed directly with official sources before this is relied upon; no success rate, fixed deadline, or non-US equivalent is established by the available evidence.

Unresolved research question: A specific mailbox recovery and closure checklist (for example, confirming absence of unauthorised rules, delegates, forwarding addresses, and application grants, and an observation period before closure) was considered during research but is not adequately supported by the source material available for this draft. Directly applicable vendor or authoritative BEC recovery guidance should be obtained before finalising this section. [Organisation/IT to supply a verified platform-specific recovery checklist.]

Author caution: Do not present the US recovery mechanism as generally available or guaranteed. Applicability depends on transaction corridor, jurisdiction, and current program eligibility. [Finance/treasury to confirm transaction corridors and jurisdiction.] Confirmation of applicable jurisdiction and transaction corridors is a blocking prerequisite for approving this section for operational use (see Scope).

6.1 Closure Criteria

The evidence available for this draft does not establish a verified, platform-specific closure checklist for BEC incidents. The criteria below distinguish matters grounded in supplied evidence, matters requiring explicit accountable-role confirmation because no verified checklist exists, and lower-materiality matters that may be accepted as residual risk. They do not constitute a complete or platform-verified closure procedure.

Must be verified before closure (grounded in supplied evidence):

- Identified malicious mailbox configuration has been removed and verified, using the deployed platform's verified procedures (see Eradication and Remediation).
- Required legal and notification assessments (see Communications and Notifications) have been completed, including confirmation of applicable jurisdiction.
- The suspected unauthorised access or fraudulent-payment pathway has been addressed per the actions actually taken and recorded in Containment.

Must be confirmed by the accountable role before closure (not established by the supplied evidence; must not be treated as automatically satisfied or as ordinary residual risk):

- A platform-specific technical recovery and closure checklist (see Recovery) has been defined and completed. [Organisation/IT to supply and verify this checklist.]
- Recovery controls have been validated before service re-enablement. [Organisation to confirm and document.]

May be documented and accepted as residual risk by [Incident Response Lead / appropriate accountable role], rather than treated as blocking closure:

- The completeness of scoping for disclosed data, affected payments, and affected parties, where scoping has been performed as far as reasonably possible given available evidence.
- The extent of evidence preservation achieved given the platform's actual logging and retention configuration.
- Outstanding, lower-materiality verification items noted elsewhere in this playbook (for example, the unresolved OAuth/token-rotation question and unverified advanced vendor telemetry), where these do not affect the specific incident's confirmed containment and eradication.

[Organisation to supply its incident severity model and closure sign-off role to complete this section.]

7. 6. Lessons Learned

Review:

- Which relevant preventive control (for example, MFA coverage, authentication path, or payment-detail verification process) was absent, bypassed, ineffective, or not applicable in this incident, based on confirmed incident evidence.
- The confirmed initial access vector (where a genuine account was compromised) and whether related controls require strengthening.
- Whether legacy authentication or other control gaps identified during Eradication and Remediation should be addressed more broadly across the organisation, subject to platform verification and service-impact assessment.
- Current incident-response practice guidance — NIST SP 800-61 Revision 3 (published April 2025) is structured around the NIST Cybersecurity Framework (CSF) 2.0 and may inform the organisation's approach to incident-response improvement. The full publication should be consulted directly before attributing specific lifecycle or "Improve" practices to it, as only the publication's landing-page details were confirmed for this draft.

[Organisation to confirm its post-incident review process, owner, and timeframe.]